

Malware Analysis Fundamentals

Classification, Analysis Methods, and SOC Workflow

Blue Team, Malware Concepts for SOC, Zen Mier

Objectives

- Understand what malware is, why it is used, and the impact it has on organizations and SOC teams.
- Learn the major malware categories and how to distinguish one from another based on observed behavior.
- Understand the difference between binary (compiled executable) and script-based malware and why that distinction matters for detection.
- Apply malware classification in a practical SOC dashboard exercise by reviewing real alerts and selecting the correct malware type.
- Understand the two core malware analysis methods: static analysis (inspecting without executing) and dynamic analysis (running in a controlled environment).
- Use REMnux command-line tools and Hybrid-Analysis.com to perform both static and dynamic analysis on a real malware sample.

Tools Used

Tool	Purpose
REMnux VM	Linux-based malware analysis distribution with pre-installed tools. Used to perform static analysis on malware samples without risk of infection.
md5sum	Generates an MD5 hash of a file. Used to uniquely identify a malware sample and check it against threat intelligence databases.
file	Identify the true file type by reading the file header, not the extension. Used to detect disguised executables.
strings	Extracts readable text from a binary file. Useful for finding embedded URLs, domain names, registry paths, and error messages.
pecheck	Inspects the PE (Portable Executable) header of Windows binaries. Reveals compilation details, imported libraries, and signs of packing.
Hybrid-Analysis.com	Free online sandbox platform combining static and dynamic analysis. Automatically runs a file in an isolated environment and reports its behavior, network activity, and dropped files.

Part 1: Malware Classification

Malware (malicious software) is any program created to harm systems, steal information, or gain unauthorized access. It appears in many forms, each with a different purpose and attack method. For a SOC analyst, identifying the type of malware quickly determines the correct response.

Malware Categories

Type	Primary Goal	How It Appears in an Alert
Ransomware	Encrypt files and demand payment	Users lose file access; a ransom note appears. Files get a new extension. Examples: Akira, WannaCry.
Spyware	Monitor activity and steal information	Sensitive emails accessed by unknown party. Keystrokes captured. Examples: Pegasus.
Keylogger	Capture every keystroke silently	Credentials appear compromised with no phishing evidence. User unaware of any interaction.
Wiper	Destroy data permanently	Files overwritten with random data, servers crash. No ransom demand. Pure destruction.
Adware	Display unwanted ads for profit	Browser floods with pop-ups. Suspicious background process found. No data theft or encryption.
Cryptominer	Use system CPU to mine cryptocurrency	Sustained high CPU usage from an unknown process. System slows down. No visible user-facing symptoms.
Data Stealer	Collect and exfiltrate credentials and files	Outbound traffic to unknown external IPs. Browser databases and document folders accessed.
C2, RAT	Provide remote attacker control of the machine	Process making regular outbound connections to an external IP. Unexpected commands executed by a system process.

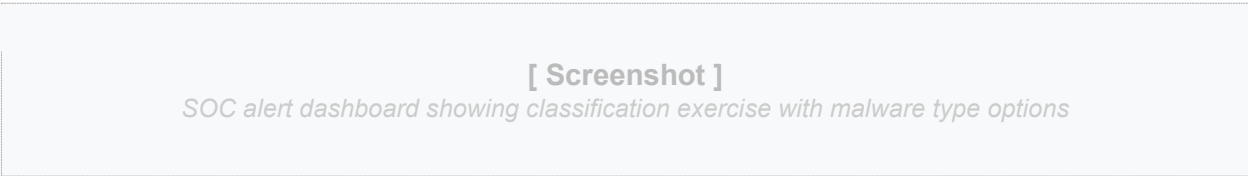
Binary vs Script-Based Malware

Binary malware is compiled with code saved as a standalone executable file (.exe, .dll). It can be analyzed using PE header tools like pecheck. It is harder to modify after compilation but leaves clear file artifacts on disk.

Script-based malware runs inside an interpreter that already exists on the target machine, such as PowerShell, Python, JavaScript, or Bash. It may leave no file on disk (fileless malware) and is more easily obfuscated. Detection relies on monitoring what the interpreter runs rather than what files exist.

SOC Dashboard Classification Exercise

A simulated SOC alert dashboard was reviewed. Each alert described a symptom, and the task was to select the correct malware classification. For example, sustained high CPU usage mapped to Cryptominer, files encrypted with a ransom note mapped to Ransomware, and constant browser pop-ups with no data theft mapped to Adware.



Caption: _____

DETECTION OPPORTUNITIES

- Alert on sustained CPU usage above 80% from a process with no legitimate network or user function.
- Alert on file extension changes in bulk across a shared folder, indicating active ransomware encryption.

- Alert outbound connections to external IPs from browsers or credential-related processes, indicating a data stealer.

Part 2: Intro to Malware Analysis

When a suspicious file is encountered, the analyst must understand what it is and what it does before taking action. Two complementary methods are used: static analysis first, then dynamic analysis if needed.

Static Analysis

Static analysis examines a file without executing it. The goal is to extract metadata and indicators that reveal the malware's nature, capabilities, and origin. All static analysis was performed on the REMnux VM using command-line tools.

- md5sum: Generates the file's MD5 hash. This hash is a fingerprint that can be checked against Virus Total or other threat intelligence platforms to instantly identify known malware.

```
ubuntu@ip-10-48-184-252:~/Desktop/Samples$ ls
redline str wannacry zmsuz3pinwl
ubuntu@ip-10-48-184-252:~/Desktop/Samples$ md5sum redline
ca2dc5a3f94c4f19334cc8b68f256259 redline
ubuntu@ip-10-48-184-252:~/Desktop/Samples$
```

- file: Identifies the true file type from the file header bytes, not the extension. An attacker may rename a .exe to .pdf, but the file command will still report it as a Windows PE executable.

```
ubuntu@ip-10-48-184-252:~/Desktop/Samples$ file redline
redline: PE32 executable (GUI) Intel 80386, for MS Windows, Nullsoft Installer self-extracting archive
ubuntu@ip-10-48-184-252:~/Desktop/Samples$
```

- strings: Extracts all readable text embedded in the binary. Common findings include hardcoded C2 domains, IP addresses, registry key paths, error messages, and encoded payloads.
- pecheck: Reads the PE header structure of Windows executables. Reveals the list of imported DLLs and API calls the malware uses, along with compilation timestamps and signs of packing (compression used to hide the real code).

```
ubuntu@ip-10-48-184-252:~/Desktop/Samples$ pecheck redline
PE check for 'redline':
Entropy: 7.999627 (Min=0.0, Max=8.0)
MD5 hash: ca2dc5a3f94c4f19334cc8b68f256259
SHA-1 hash: ce9943d9efc7d5f10cac4ab0b5aa48d62a063852
SHA-256 hash: e8ba49a75de083cb786e8ed84972affa11542dd913f1a07b0d44e1d45e5e22e9
SHA-512 hash: 8c774f64631342c2465d166cd4c374356c40c1cf6bae13b2e0b003ce6c85e397da799f111cbbcd638d548029c555f31156c2633d531falb20160d7904fa17d75
.text entropy: 6.453919 (Min=0.0, Max=8.0)
.rdata entropy: 5.136718 (Min=0.0, Max=8.0)
.data entropy: 4.096809 (Min=0.0, Max=8.0)
.ndata entropy: 0.000000 (Min=0.0, Max=8.0)
.rsrc entropy: 4.209687 (Min=0.0, Max=8.0)
Dump Info:
-----DOS_HEADER-----
```

Dynamic Analysis

Dynamic analysis runs the malware in a controlled, isolated environment and observes what it does. This is necessary when static analysis is inconclusive or when the malware uses packing or obfuscation to hide its true behavior.

For this lab, the online platform Hybrid-Analysis.com was used. It accepts file or URL submissions, runs them in an isolated sandbox, and produces detailed report covering static indicators, a dynamic behavior timeline, process execution tree, network connections, DNS queries, dropped files, and extracted strings.

Analysis of the Redline stealer sample showed the malware executing cmd.exe, deleting volume shadow copies (a ransomware-associated action to prevent file recovery), and making multiple network

connections to external servers. These findings were all visible in the Hybrid-Analysis process tree and network analysis sections.

redline

This report is generated from a file or URL submitted to this webservice on September 9th 2023 17:01:54 (UTC) (Full Details)
Guest System: Windows 10 64 bit, Professional, 10.0 (build 16299),
Report generated by Falcon Sandbox © Hybrid Analysis

malicious

Threat Score: 100/100
AV Detection: 74%
Labeled as: Dropper.Trojan.Agent
#socalars #stealer

Overview | Sample unavailable | Copy | Downloads | External Reports | Re-analyze | Hash Seen Before | Show Similar Samples

Report False-Positive | Request Report Deletion

Post | Link | E-Mail

Incident Response

Risk Assessment

Spyware

Found a string that may be used as part of an injection method
Found browser information locations related strings

Persistence

Installs hooks/patches the running process
Spawns a lot of processes

Fingerprint

Queries sensitive IE security settings
Queries the display settings of system associated file extensions

Evasive

Contains ability to check if a debugger is running
Marks file for deletion
PE file has a section name known to be used by a packer/protector

MITRE ATT&CK™ Techniques Detection

This report has 231 indicators that were mapped to 87 attack techniques and 11 tactics. View all details

Hybrid Analysis

Tip: Click an analysed process below to view more details.

Analysed 17 processes in total.

redline.exe (PID: 1888) 52/70

setup_installer.exe (PID: 3900) 41/70 Hash Seen Before

setup_install.exe (PID: 7308) 42/68 Hash Seen Before

cmd.exe %WINDIR%\system32\cmd.exe /c powershell -inputformat none -outputformat none -NonInteractive -Command Add-MpPreference -ExclusionPath "%TEMP%\ (PID: 2712) Hash Seen Before

powershell.exe powershell -inputformat none -outputformat none -NonInteractive -Command Add-MpPreference -ExclusionPath "%TEMP%\ (PID: 7528) Hash Seen Before

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa25bdfc_Sat15d93b81243b.exe (PID: 8096) Hash Seen Before

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa38bcf4_Sat15f98352f48.exe (PID: 3364) Hash Seen Before

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa44c09c_Sat15f6e00f22a4.exe (PID: 3352)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa56f568_Sat15e879a10c5.exe (PID: 2676)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa63049c_Sat15e844e2af9.exe (PID: 2812)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa8c3051_Sat155cbde0cfb2.exe (PID: 2820)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fa9b2b38_Sat157dle38e.exe (PID: 2836)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fab2cfab_Sat1500aa1ec1ab.exe (PID: 2880)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fad01b21_Sat15bb83952787.exe /mixtwo (PID: 3048)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fade2cc5_Sat151e15a05.exe (PID: 5908)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fafd9ca1_Sat1555adef0.exe (PID: 7064)

cmd.exe %WINDIR%\system32\cmd.exe /c 62237fb0d0dd1_Sat159fc8bb76b4.exe (PID: 6580)

Investigation Methodology

Step	Action	Detail
1	Hash and Identify	Run md5sum and file. Check hash against Virus Total or Hybrid-Analysis to see if the sample is already known.
2	Extract Strings	Run strings to pull readable text. Look for URLs, domains, IP addresses, registry paths, and API names.

3	Inspect PE Header	Run pecheck to review imported libraries and functions. Flag any networking, cryptography, or process-injection-related imports.
4	Sandbox Submission	Submit to Hybrid-Analysis if static analysis is incomplete. Review process tree, network activity, and dropped files in the report.
5	Document IOCs	Record the file hash, any embedded URLs or domains, registry keys, process names, and network endpoints as indicators of compromise.

Summary

This lab covered the foundational knowledge every SOC analyst needs before performing any malware-related investigation. Knowing the difference between ransomware and a wiper, or between a cryptominer and a data stealer, directly determines how fast and how correctly a threat is contained. The hands-on analysis exercises demonstrated that static and dynamic methods complement each other. Static analysis is fast and safe but can be defeated by obfuscation. Dynamic analysis reveals actual behavior but takes more time and requires a controlled environment. A real investigation uses both.

Area Covered	Key Takeaway
Malware Classification	Learned 8 malware categories with real-world examples. Applied classification in a simulated SOC dashboard alert review.
Binary vs Script	Binary malware leaves PE artifacts on disk. Script-based malware may be fileless and relies on monitoring interpreter behavior.
Static Analysis	Used md5sum, file, strings, and pecheck on REMnux to extract hashes, file type, embedded strings, and PE imports.
Dynamic Analysis	Used Hybrid-Analysis.com to observe Redline stealer behavior: process tree, shadow copy deletion, and network connections.
Tools	REMnux VM, md5sum, file, strings, pecheck, Hybrid-Analysis.com.